Module 2 Learner Guide: Assessing Cyber Risks and Threat Modeling

Oct 19, 2026 · @Nenji

Start here

This afternoon you learn to find weak spots, predict where attacks will come from, and spot attacks aimed at people. Then your team produces a threat model and risk matrix for the fictional RSSO portal, worth 20% of your grade. Quiz 2 adds another 10%.

Item	Detail
Module	2 of 5: Assessing Cyber Risks and Threat Modeling
Dates	Face-to-face: Wednesday 21 October 2026. Online: Monday 26 October 2026
Time	4 hours, 1:00 to 5:00 PM (Day 1 afternoon)
Syllabus items	2.1, 2.2, 2.3
Graded	Quiz 2: 12 items, 15 minutes, 10%. Team risk assessment: 20%

What you will be able to do

Level	By 5:00 PM you will be able to	Where you practise
Remember	Recall the seven risk words, the six STRIDE threats, TARA and SLAM	Check yourself; Quiz 2
Understand	Explain the difference between a threat, a weakness and a risk, using the house comparison	Lesson 2.1
Apply	Spot weaknesses in office situations, and tell phishing from genuine messages	Try it 2.1 and 2.3
Analyze	Draw where data flows in a system, and ask what can go wrong at each step	Lesson 2.2 worked example; risk assessment

Level	By 5:00 PM you will be able to	Where you practise
Evaluate	Rate risks by likelihood and impact, and decide which to treat first	Risk assessment
Create	Produce a threat model and risk register with your team	Risk assessment (graded)

The afternoon

Time	Segment
1:00 to 1:10	Recall from this morning; afternoon roadmap
1:10 to 1:50	2.1 Vulnerabilities and personal data
1:50 to 2:35	2.2 Predicting where attacks come from
2:35 to 2:45	Break
2:45 to 3:25	2.3 Attacks aimed at people
3:25 to 3:35	Break
3:35 to 3:50	Quiz 2
3:50 to 4:45	Team risk assessment (graded, 20%)
4:45 to 5:00	Questions, Day 1 close, Day 2 preview

Your team stays the same as this morning. Bring this morning's data map if you made one: it helps in the risk assessment.

Lesson 2.1: Vulnerabilities and personal data in government systems

Key idea: a risk is a threat meeting a weakness in something you value. Find the weaknesses first, starting with where personal data lives.

Explain it like this: a house

Word	Plain meaning	In a house	At the RSSO
Asset	Something of value	Your house and what is inside	The applicant database

Word	Plain meaning	In a house	At the RSSO
Threat	Something that could cause harm	A burglar	A criminal group after ID numbers
Vulnerability	A weakness a threat can use	A window left unlocked	An admin page open to the internet with a default password
Likelihood	How probable it is	How often burglars try that street	How often such pages are attacked
Impact	How bad it would be	What you would lose	48,000 people's sensitive data exposed
Risk	Likelihood combined with impact	The chance of losing your valuables, and how much	A data breach the office must report
Control	A measure that lowers the risk	A lock, a grille, a dog	A strong unique password, MFA, no public admin page

Remember: no weakness, no risk, even if threats exist. Most of your power is in removing weaknesses.

Where weaknesses hide: People, Process, Technology

Where	Common weaknesses in offices	RSSO example
People	Shared accounts; untrained staff; passwords written down	One login for the whole approval team
Process	No routine to remove access when people leave; backups never test-restored; no check before changing payment details	A contractor who left two months ago can still log in
Technology	Unpatched or unsupported systems; default passwords; admin pages open to the internet; files shared by public link; outdated website plugins; unencrypted laptops and USB sticks; one flat network; lapsed security licences	The server's operating system reached end of support last year

What the numbers say

Verizon's 2026 Data Breach Investigations Report studied more than 22,000 confirmed breaches in 145 countries (SecurityWeek, 19 May 2026; TechRepublic, 21 May 2026):

- **Unfixed weaknesses are now the top way in:** exploiting vulnerabilities started 31% of breaches, ahead of stolen credentials at 13%.
- **Fixes are slow:** for the most serious known-exploited weaknesses, the median time to fix rose to 43 days, and only 26% were fully fixed.
- **Vendors are part of your risk:** 48% of breaches involved a third party, up from 30% a year earlier.

Managing weaknesses

1. **Know what you have.** You cannot protect what you have not listed: keep an inventory of systems and information (ISO 27001 control 5.9).
2. **Patch on a schedule.** Apply security updates regularly, fastest for weaknesses known to be exploited, and renew licences before they expire.
3. **Test only with permission.** Scanning or probing a system without authority can be illegal access under the Cybercrime Prevention Act (RA 10175). Only authorized staff or contractors test, and only in writing.
4. **Use severity scores as an input, not the decision.** The Common Vulnerability Scoring System (CVSS) rates technical severity from 0 to 10: Low 0.1 to 3.9, Medium 4.0 to 6.9, High 7.0 to 8.9, Critical 9.0 to 10.0. A Medium weakness on the system that holds 48,000 records may matter more than a High one on a test machine.

Personal data has a life cycle

Personal data is most at risk where it moves or is copied. Follow it from start to end:

Stage	Where it leaks	Rule to apply
Collect	Forms asking for more than needed	Little: collect only what the purpose needs
Store	Spreadsheets on desktops; unencrypted laptops	Keep it in approved, access-controlled places
Use	Shared logins; screens visible to visitors	One account per person; need-to-know access
Share	Email attachments; chat groups; public links; vendor exports	Share only with those entitled, through approved, secure channels

Stage	Where it leaks	Rule to apply
Keep	Old copies in backups and test systems	Keep only as long as needed
Dispose	Printouts in the trash; old drives sold or thrown away	Shred paper; wipe or destroy drives (improper disposal is a crime under Sec. 27 of the DPA)

Try it 2.1: Spot the weakness (Apply, 10 minutes, teams)

For each RSSO situation, name the weakness, say whether it sits in people, process or technology, name the data at risk, and suggest one fix.

1. The Assistance Portal's admin page can be reached from the internet, and it still uses the vendor's default password.
2. The whole approval team uses one login for the approval spreadsheet.
3. A contractor who left two months ago can still connect through the VPN.
4. Backups run every night, but no one has ever tried to restore one.
5. Field staff carry applicant forms on their personal USB sticks.
6. The server's operating system reached end of support last year and no longer receives security updates.

Check yourself 2.1

1. In the house comparison, what is the vulnerability?
2. Name the three places where weaknesses hide.
3. In Verizon's 2026 report, what was the most common way attackers got in?
4. Why is a CVSS score not enough to decide what to fix first?

Lesson 2.2: Predicting where attacks may come from

Key idea: draw where the data goes, then ask what can go wrong at each step. This is called threat modeling, and anyone who knows a process can do it.

Four questions

Threat modeling is built on four questions (Threat Modeling Manifesto):

1. What are we working on?
2. What can go wrong?
3. What are we going to do about it?
4. Did we do a good enough job?

Step 1, draw it: a data flow map uses five shapes

Shape	Means	RSSO example
Rectangle	Someone or something outside the system	A citizen; the SMS vendor
Circle	A step that handles data	"Check application"
Two parallel lines	A place where data is stored	The applicant database; a spreadsheet
Arrow	Data moving	Application details sent to the portal
Dashed line	A trust boundary: where data passes into someone else's control	Between the internet and the office; between the office and a vendor

Trust boundaries matter most: attacks usually happen where data crosses one.

Step 2, find what can go wrong: STRIDE

STRIDE is a checklist of six kinds of threats, from Microsoft (Microsoft Learn). Three of them are Secret, Correct, Ready failures; the other three are about identity: who you are, what you did, and what you may do.

Letter	Threat	Plain meaning	What it breaks	RSSO example
S	Spoofing	Pretending to be someone else	Authentication (who you are)	Someone logs in with Ben's stolen password
T	Tampering	Changing data without permission	Integrity (Correct)	A payout amount is edited in the spreadsheet
R	Repudiation	Denying you did something, with no record to prove it	Non-repudiation (what you did)	A shared login means no one can tell who approved a payout
I	Information disclosure	Data seen by the wrong people	Confidentiality (Secret)	The applicant list shared by a public link

Letter	Threat	Plain meaning	What it breaks	RSSO example
D	Denial of service	Making the system unavailable	Availability (Ready)	Ransomware or floods of traffic take the portal down
E	Elevation of privilege	Getting powers you should not have	Authorization (what you may do)	A clerk account reaches the admin page

Step 3, see the attack path

Attackers move in steps. Lockheed Martin's Cyber Kill Chain names seven: reconnaissance (research), weaponization (prepare), delivery (for example a phishing email), exploitation (break in), installation (settle in), command and control (take remote control), and actions on objectives (steal, lock or destroy). Each step is a chance to spot and stop them (EC-Council).

IT depth: MITRE ATT&CK is a free knowledge base of real attacker behaviour. Its Enterprise matrix (version 18, October 2025) groups techniques under 14 tactics, from reconnaissance to impact (MITRE).

Step 4, rate and treat: the 5 by 5 matrix and TARA

Rate each threat's **likelihood** from 1 (rare) to 5 (almost certain) and its **impact** from 1 (minor) to 5 (severe). Multiply them for a score from 1 to 25. This course uses these bands:

Likelihood ↓ / Impact →	1 Minor	2 Moderate	3 Serious	4 Major	5 Severe
5 Almost certain	5 Medium	10 High	15 High	20 Critical	25 Critical
4 Likely	4 Low	8 Medium	12 High	16 High	20 Critical
3 Possible	3 Low	6 Medium	9 Medium	12 High	15 High
2 Unlikely	2 Low	4 Low	6 Medium	8 Medium	10 High
1 Rare	1 Low	2 Low	3 Low	4 Low	5 Medium

Bands: Low 1 to 4, Medium 5 to 9, High 10 to 16, Critical 20 to 25. Treat Critical and High risks first.

Then choose one of four treatments. Remember **TARA**:

Treatment	ISO/IEC 27005 word	Plain meaning	Example
Transfer	Sharing	Pass part of the consequence to someone else	Insurance; a vendor contract with security duties
Avoid	Avoidance	Stop the activity that creates the risk	Stop collecting a field you do not need
Reduce	Modification	Add a control that lowers likelihood or impact	MFA, encryption, training
Accept	Retention	Keep the risk, with written approval	A Low risk that costs more to fix than it could lose

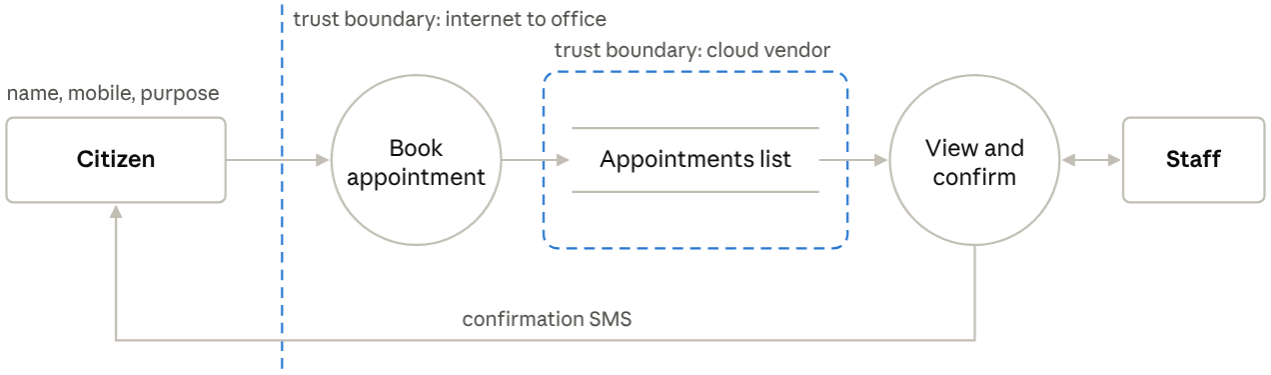
Record each risk in a **risk register**: the risk, its owner, likelihood, impact, score, treatment, and the risk left after treatment.

Worked example: the RSSO's online appointment booking page

Citizens book an office visit online by giving their name, mobile number and purpose. The entries are saved in a list kept by a cloud form service. Staff check the list and send a confirmation by SMS.

Applicant data crosses two trust boundaries

RSSO online appointment booking page, worked example



data flow map · 2 people or systems outside, 2 steps, 1 store, 2 trust boundaries

Rectangles are people outside the system, circles are steps that handle data, the two lines are where data is stored, and dashed lines are trust boundaries. The citizen's data crosses from the internet into the office, then into a vendor's cloud service: those two crossings are where attacks are most likely.

Three STRIDE threats

Element	STRIDE	Threat	Control
Book appointment	Spoofing	Someone books in another person's name and number	A one-time code sent to the mobile number
Appointments list	Information disclosure	The list is shared by a public link	Access only for named staff accounts
Book appointment	Denial of service	Automated fake bookings fill every slot	Limit bookings per number; a human check

Two risk register entries

Risk	Owner	Likelihood	Impact	Score	Treatment
Appointments list exposed by a public link	Ana (IT officer)	4	3	12 High	Reduce: remove public links, named accounts only
Fake bookings fill the calendar	Ben (records clerk)	3	2	6 Medium	Reduce: booking limit per number; review daily

Check yourself 2.2

1. What are the four threat modeling questions?
2. What does a dashed line mean on a data flow map, and why does it matter?
3. Which three STRIDE threats match Secret, Correct and Ready?
4. A risk has likelihood 4 and impact 4. What is its score and band?
5. What do the letters of TARA stand for?

Lesson 2.3: Attacks aimed at people

Key idea: attackers trick people because it is cheaper than breaking systems: one convincing message can open every door. Your best defense is a habit: pause, verify, report.

In Verizon's 2026 report, 62% of breaches involved the human element, such as a mistake, a click on a phishing link or a misused password. Social engineering caused 16% of breaches, and phishing on mobile phones succeeded more often than by email (a median 40% higher success rate) (SecurityWeek, 19 May 2026).

The tricks, in plain words

Trick	What it looks like
Phishing	A fake email that gets you to click, open a file, or give a password
Spear phishing	Phishing written for you personally, using your name, office or boss
Whaling	Phishing aimed at heads of office and senior officials
Smishing	Phishing by text message, often with a short link
Vishing	Phishing by voice call, often a caller posing as an agency, a bank or the police
Quishing	A QR code that leads to a fake page
Business email compromise	A fake or hijacked supplier or official account asks to change bank details or pay an urgent invoice
Pretexting	A made-up story to get information, such as "I'm from IT and need your one-time code"
MFA fatigue	Repeated sign-in approval prompts until someone taps Approve to make them stop
Tailgating	Following an authorized person through a secured door
USB baiting	A "lost" USB stick left for someone to plug in
Deepfakes	AI-made voice or video of a real person, such as a boss asking for a transfer

Two real examples:

- **Callers posing as DICT staff.** In September 2024, the CICC warned of callers claiming to be from DICT who said a person's SIM card was "recommended for suspension" over illegal activity. Its advice: ignore such calls and report them to hotline 1326 (PNA, 26 September 2024).
- **A deepfake video call.** In February 2024, a finance employee at a multinational company's Hong Kong office joined a video call with what looked like the company's chief financial officer and colleagues. Everyone else on the call was a deepfake. The employee made 15 transfers totaling HK$200 million, about US$25.5 million (Security Affairs, 5 February 2024).

Ransomware usually enters the same way: through a phishing message or a stolen password, then attackers spread inside, steal data and lock files.

Check a message with SLAM

Letter	Check	Warning signs
S	Sender	A name you know but an odd address; a free email account for an "official" message; a slightly misspelled agency domain
L	Links	The real address (hover or long-press) does not match the sender; short links; login pages reached from a message
A	Attachments	Files you did not expect, especially archives, documents asking you to enable content, or "invoices"
M	Message	Urgency, threats, rewards, secrecy, or requests for passwords, one-time codes, payments or changes to bank details

Then: **pause, verify, report.** Verify through a number or address you already know, never one given in the message. Never share a one-time code with anyone.

Defense in layers

Layer	What it means	Examples
People	Staff who recognize tricks and report without fear	Short regular awareness sessions; a no-blame reporting channel
Process	Routines that do not depend on one person being fooled	A call-back to a known number and a second approver before any payment or bank-detail change
Technology	Tools that block or limit the damage	Email filtering; phishing-resistant MFA; least privilege; offline backups

IT depth: three email records help receivers spot forged mail from your domain. SPF lists the servers allowed to send for your domain. DKIM signs each message so changes can be detected. DMARC tells receivers what to do with mail that fails those checks (none, quarantine or reject) and sends you reports (Vortenza guide).

Where to report

What happened	Report to
A suspicious message or call at work, or you clicked something	Your IT unit or DPO, at once. Speed matters more than embarrassment
A scam aimed at you or at citizens	Hotline **1326**, the government's 24/7 Inter-Agency Response Center (CICC, DICT, NTC and NPC, with the PNP and NBI as its law enforcement arm) (PNA), or **CICC ScamSafe**, the reporting and information platform launched on 19 December 2025 (Newsbytes)
You want a second opinion on a message	ScamCheck.ph, a free checker by the volunteer civic-tech group BetterGov.PH. It is not an official government tool: remove names, account numbers and one-time codes first, and never use it for official records

Under the Anti-Financial Account Scamming Act (RA 12010, 20 July 2024), tricking someone into giving their account details (a social engineering scheme) and letting your account be used to move scam money (money muling) are crimes. Never lend or sell access to your e-wallet or bank account (RA 12010).

Try it 2.3: Phish or legit? (Apply, 15 minutes, teams)

All messages are fictional. For each, vote phish or legit, then name the warning signs using SLAM.

1. An email titled "DICT Advisory: verify your government mailbox within 24 hours", with a link to dict-gov-ph.verify-portal.example.
2. An email from a regular supplier: "We have changed banks. Please pay invoice 4471 to our new account today."
3. A text message: "RSSO: your assistance payout is on hold. Update your details at" followed by a short link.
4. A voicemail from a caller who says he is from law enforcement and asks you to call back and give the one-time code sent to your phone to "confirm SIM ownership".
5. A poster taped outside the office with a QR code: "Scan to claim your cash aid today."
6. A message from a colleague's account: "Pls review this file urgently", with a link to a page that asks for your email password.

7. An email from HR's usual address, with no link or attachment, reminding staff of tomorrow's training, matching the memo on the bulletin board.
8. A text from your bank's registered sender name telling you a transaction occurred, with no link, and advising you to call the number on the back of your card if it was not you.

Check yourself 2.3

1. What does SLAM stand for?
2. Why should you verify through a number you already know, not one in the message?
3. Where should a citizen report a scam call?
4. Name one process control that stops a fake bank-detail change.

Graded risk assessment: the RSSO Assistance Portal (20%)

Your team builds a threat model and a risk register for the fictional RSSO Assistance Portal, using the four steps of Lesson 2.2. Every member receives the team score.

Item	Detail
Time	3:50 to 4:45 PM: brief 5 minutes, build 35, gallery feedback 10, submit 5
Submit	One file per team through the submission link. Deadline 4:45 PM; if connectivity fails, the grace period runs until 8:00 AM the next day
Format	Face-to-face: A3 sheets photographed, plus the typed tables. Online: your team's shared document

The scenario (fictional)

- Citizens apply for assistance on the RSSO Assistance Portal. They upload a valid ID and, for medical assistance, a medical certificate. Each application holds name, address, birthdate, mobile number, government ID number, health information and e-wallet number.
- Applications are saved in the applicant database on the office server, in the server room.
- Ben exports new applications to a shared approval spreadsheet, where supervisors approve them.

- Dan uploads approved payouts (names, e-wallet numbers and amounts) to the e-wallet provider's business portal.
- An SMS vendor receives names and mobile numbers through a system link and texts status updates to applicants.
- Ana manages the server. Remote staff connect through a VPN, and some staff open the approval spreadsheet on personal phones.
- Each night, a backup is copied to a USB drive kept in the server room.

A starter list for your map

Use these to begin; add anything you think is missing.

Shape	Elements
Rectangles (outside the system)	Citizen; SMS vendor; e-wallet provider; staff working from home
Circles (steps)	Submit application; approve application; pay out; send SMS update
Two lines (stores)	Applicant database; approval spreadsheet; backup USB drive
Dashed lines (trust boundaries)	Decide where data passes into someone else's control

What to submit

1. **A data flow map** with every trust boundary marked.
2. **At least 8 threats**, each with its STRIDE letter and the element it attacks.
3. **A 5 by 5 risk matrix** with your top 5 risks placed, each with a one-line reason for its ratings.
4. **For each top-5 risk:** a TARA treatment, a control, and an owner from the RSSO cast.
5. **A contribution line:** each member's name and what they did.

Threat table

#	Element	STRIDE letter	What could go wrong	Who is harmed
1				
2				
3				

#	Element	STRIDE letter	What could go wrong	Who is harmed
4				
5				
6				
7				
8				

Risk register (top 5)

Rank	Risk	Owner	Likelihood (1 to 5)	Impact (1 to 5)	Score and band	Treatment (TARA)	Control	Reason for the ratings
1								
2								
3								
4								
5								

How it is scored (100 points, scaled to 20%)

Criterion	Points	Full marks means
Scope and scenario understanding	15	Assets, data and the system boundary are stated correctly
Threat model	35	A data flow map with trust boundaries; at least 8 threats mapped to STRIDE and to the element they attack
Risk matrix	30	Likelihood and impact rated consistently and justified; the top 5 risks prioritized
Treatment	20	Each top risk has a relevant control, an owner and a TARA treatment

Tips for mixed teams

- Start with the citizen: what could go wrong for the people whose data this is?
- Non-IT members often spot the process weaknesses first: approvals, exports, payouts, backups. IT members help name them with STRIDE.

- Rotate roles from this morning: facilitator, scribe, map drawer, timekeeper, presenter.
- Use the five shapes only. A neat map matters less than a complete one.

Desk card: Module 2 additions

Add these to this morning's desk card.

Remember	What it means	What you do
The house	Asset, threat, vulnerability, likelihood, impact, risk, control	Find and remove weaknesses: no weakness, no risk
People, Process, Technology	Where weaknesses hide	Check all three, not only technology
Four questions	What are we working on? What can go wrong? What will we do about it? Did we do a good enough job?	Ask them about any process before it changes
STRIDE	Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege	Ask each one at every trust boundary
5 by 5	Likelihood times impact: Low 1 to 4, Medium 5 to 9, High 10 to 16, Critical 20 to 25	Treat Critical and High first
TARA	Transfer, Avoid, Reduce, Accept	Choose one for every risk, with an owner
SLAM	Sender, Links, Attachments, Message	Then pause, verify through a known number, report
1326	The government's 24/7 scam hotline; also CICC ScamSafe	Report scams; report work incidents to your IT unit or DPO

Glossary additions

Term	Plain meaning
Business email compromise	A fake or hijacked supplier or official email used to redirect payments

Term	Plain meaning
CVSS	A 0 to 10 score of how technically severe a weakness is
Data flow map	A drawing of where data comes from, where it goes and where it is stored
Impact	How bad the harm would be if a risk happened
Kill chain	The steps an attacker takes, from research to reaching the goal
Likelihood	How probable it is that a risk happens
MFA fatigue	Sending repeated sign-in prompts until someone approves one
Money muling	Letting your account be used to move money from scams or crimes
Pretexting	Using a made-up story to get information
Quishing	Phishing through a QR code
Risk register	A list of risks with owners, ratings and treatments
STRIDE	A checklist of six threats: spoofing, tampering, repudiation, information disclosure, denial of service, elevation of privilege
Tailgating	Following someone through a secured door
Threat modeling	Drawing a system and asking what can go wrong, step by step
Trust boundary	A point where data passes into someone else's control
Vishing	Phishing by voice call
Vulnerability	A weakness a threat can use
Whaling	Phishing aimed at senior officials

Answers

Model answers: a different answer with a sound reason can also be right.

Lesson 2.1

Check yourself: 1. The unlocked window. 2. People, process and technology. 3. Exploiting vulnerabilities, at 31% of breaches. 4. CVSS measures technical severity, not what the weakness would cost your office; a Medium weakness on the system holding 48,000 records may matter more than a High one on a test machine.

Try it 2.1

#	Weakness	Where	Data at risk	One fix
1	Admin page open to the internet with a default password	Technology	Every applicant record	Close the admin page to the internet; change the password; add MFA
2	Shared login	People and process	The approval spreadsheet and payouts	One account per person, with logs
3	Access not removed when a contractor left	Process	Everything the VPN reaches	Disable accounts on the last day; review accounts monthly
4	Backups never test-restored	Process	All data, if ransomware strikes	Test a restore regularly; keep an offline copy
5	Applicant forms on personal USB sticks	Technology and process	Sensitive applicant data	Office-issued encrypted USB sticks, with the head's approval and at most 1,000 records at a time (DPA Sec. 23)
6	Operating system out of support	Technology	The server and everything on it	Plan the upgrade; meanwhile isolate it and record the risk

Lesson 2.2

Check yourself: 1. What are we working on? What can go wrong? What are we going to do about it? Did we do a good enough job? 2. A trust boundary: where data passes into someone else's control. Attacks usually happen where data crosses one. 3. Information

disclosure (Secret), tampering (Correct), denial of service (Ready). 4. 16, High. 5. Transfer, Avoid, Reduce, Accept.

Lesson 2.3

Check yourself: 1. Sender, Links, Attachments, Message. 2. The scammer controls any number or link in the message. 3. Hotline 1326, or CICC ScamSafe. 4. A call-back to a number already on file, plus a second approver, before any bank-detail change.

Try it 2.3

#	Verdict	Warning signs
1	Phish	A look-alike address that is not a .gov.ph domain; a 24-hour deadline; a login link
2	Phish until verified (business email compromise)	A bank-detail change plus urgency. Call the supplier on the number in your files and get a second approval
3	Phish (smishing)	A short link; pressure about a payout; a request to update details by text
4	Phish (vishing)	Authority and a request for a one-time code. Never share a one-time code; report to 1326
5	Phish (quishing)	A QR code on an unofficial poster leading to a claim page. Check the office's official channels
6	Phish from a hijacked account	Urgency, an unusual tone, and a link to a password page. Call your colleague to check
7	Legit	A known sender, no link or attachment, and it matches the memo
8	Legit	No link, and it tells you to call a number you already have, the one on your card

Quiz 2

Quiz 2 has 12 items in 15 minutes, closed book, one attempt, worth 10%: vulnerabilities and personal data (4), threat modeling and risk (5), and attacks aimed at people (3). Ten items are multiple choice and two are true or false. The Check yourself questions and the desk

card are the best way to prepare.

Where each fact comes from

Every fact in this guide was checked on 19 October 2026. This is training material, not legal advice.

- Threat modeling questions: Threat Modeling Manifesto
- STRIDE: Microsoft Learn
- Cyber Kill Chain: EC-Council; MITRE ATT&CK v18: MITRE
- Verizon 2026 Data Breach Investigations Report: SecurityWeek, 19 May 2026; TechRepublic, 21 May 2026
- CVSS severity bands: Codefresh, CVSS v4.0 severity levels
- Risk treatments in ISO/IEC 27005: study guide
- SPF, DKIM and DMARC: Vortenza guide
- Hotline 1326: PNA; CICC ScamSafe: Newsbytes, 20 Dec 2025; SIM suspension scam warning: PNA, 26 Sep 2024
- Deepfake video call, Hong Kong: Security Affairs, 5 Feb 2024
- Laws: RA 12010, Anti-Financial Account Scamming Act; RA 10175, illegal access; RA 10173, Sections 23 and 27